

기업용 생성형 AI 챗봇의 RAG 문서 오염 위험 탐지를 위한 재현성 중심 보안 감사 프레임워크 연구

A Reproducibility-Centered Security Audit Framework for Detecting RAG Document Contamination Risks in Enterprise Generative AI Chatbots

> 본 원고는 한국산학기술학회논문지(JKAIS) 투고형 모의논문 초안이다. 최종 제출 전 공식 HWP 양식에 맞춘 편집, 저자 정보 입력, PDF 변환 확인이 필요하다.

국문초록

기업용 생성형 AI 챗봇은 내부 문서를 검색해 답변하는 RAG 구조를 채택하면서 업무 효율을 높이지만, 검색 문서가 오염되거나 민감정보를 포함할 경우 간접 프롬프트 인젝션과 정보 노출 위험이 발생한다. 본 연구는 문서 수집, 전처리, 색인, 검색, 생성, 사람 검토, 감사 로그를 하나의 절차로 묶는 재현성 중심 보안 감사 프레임워크 RAG-DOCGUARD를 제안한다. 100개 synthetic RAG 문서 데이터셋을 구축하고 no filter, keyword, regex baseline과 비교하였다. 실험 결과 제안 방식은 본 synthetic 조건에서 위험 문서 탐지 F1 - score 1.000000을 기록했다. 다만 이는 실제 LLM 성능이 아니라 규칙 기반 모의평가 결과이며, 실제 운영 적용 전 추가 검증이 필요하다.

영문초록

Enterprise generative AI chatbots increasingly rely on retrieval - augmented generation (RAG) to ground answers in internal documents. This architecture improves task support, but it also introduces a document - level attack surface: contaminated documents can inject indirect instructions, outdated policies can be retrieved as authoritative context, and sensitive placeholders or internal technical information can be exposed through generated answers. This paper proposes RAG - DOCGUARD, a reproducibility - centered security audit framework for detecting RAG document contamination risks before indexing and during retrieval and generation. The framework audits document provenance, preprocessing logs, risk patterns, risk scores, policy decisions, retrieval validation, output validation, human review, and run logs. To support reproducible evaluation, we construct a 100 - row fully synthetic RAG security dataset covering normal documents, indirect prompt injection, privacy leakage, source conflict, outdated policy, and hallucination - triggering documents. We compare three baselines, no filter, keyword filter, and regex filter, with the proposed rule - based framework. In the synthetic setting, RAG - DOCGUARD achieves precision, recall, and F1 - score of 1.000000 while maintaining a zero leakage rate. These results should be interpreted as a reproducibility and audit - procedure validation, not as evidence of real - world LLM security performance.

국문 키워드

생성형 AI 보안, RAG, 프롬프트 인젝션, 문서 오염, 민감정보 노출, 보안 감사, 재현성

English Keywords

Generative AI Security, Retrieval - Augmented Generation, Prompt Injection, Document Contamination, Sensitive Information Leakage, Security Audit, Reproducibility

1. 서론

1.1 연구 배경

기업은 생성형 AI 챗봇을 업무 지식 검색, 보안 점검, 고객 지원, 내부 규정 질의응답에 적용하고 있다. 특히 RAG는 사전 학습 모델의 한계를 보완하기 위해 내부 문서와 외부 지식을 검색 context로 주입한다. 국내에서도 생성형 AI 저작권

침해 대응 메커니즘[D1], 기업용 생성형 AI 시스템의 보안 위협과 대응 방안[D3], 국방 폐쇄망 환경의 생성형 AI 보안 감사 에이전트[D2], 기업 맞춤형 RAG 챗봇 구축[D6]이 논의되고 있다.

1.2 기업용 RAG 챗봇의 보안 문제

RAG의 핵심 위험은 모델 자체보다 검색 context에 있다. 공격자가 문서 저장소에 오염 문서를 넣거나, 오래된 정책 문서가 최신 규정처럼 검색되거나, 내부 문서에 민감정보가 포함되면 생성 응답은 이를 권위 있는 근거로 사용할 수 있다. 해외 연구는 LLM 보안 · 프라이버시[I2][I3], RAG 구조[I4][I5], prompting framework의 trust boundary[I6], 간접 프롬프트 인젝션[I7]을 주요 위험 축으로 제시한다.

1.3 연구 목적

본 연구의 목적은 기업용 RAG 챗봇에서 문서 오염, 간접 프롬프트 인젝션, 민감정보 노출, 출처 충돌, 오래된 정책, 환각 유도 문서를 사전에 탐지하는 감사 절차를 제안하고, 데이터셋과 코드를 공개 가능한 형태로 구성해 재현성을 확보하는 것이다.

1.4 연구 기여점

첫째, 기업용 RAG 시스템의 문서 수집부터 생성 응답 검증까지 이어지는 공격면을 단계별로 정리한다. 둘째, RAG-DOCGUARD라는 재현성 중심 감사 프레임워크를 제안한다. 셋째, 실제 개인정보와 실제 공격 payload를 포함하지 않는 100개 synthetic 데이터셋을 제공한다. 넷째, baseline 3종과 제안 방식의 정량 평가 결과를 실행 로그와 함께 제시한다.

1.5 논문 구성

2장은 관련 연구, 3장은 위협 모델과 연구질문, 4장은 제안 프레임워크, 5장은 실험 설계, 6장은 실험 결과, 7장은 논의와 한계, 8장은 결론을 제시한다.

2. 관련 연구

2.1 생성형 AI 보안 위협

국내 연구는 생성형 AI의 저작권 침해 대응과 통합 대응 메커니즘[D1], 생성형 AI 시스템의 모델 · 데이터 · 인프라 보안, 내부자 위협, 감사 체계[D3], LLM · RAG · 딥페이크 위협의 다층 거버넌스[D4]를 다룬다. 해외 survey는 LLM의 보안 · 프라이버시 위협을 데이터 추출, prompt attack, 민감정보 노출, 평가 오염, 취약 코드 생성 등으로 분류한다[I2][I3].

2.2 RAG 시스템과 문서 오염

RAG는 검색된 문서를 LLM 입력 context에 넣어 답변을 생성한다. GraphRAG와 graph-based RAG 연구는 문서, 엔티티, 관계, provenance의 중요성을 강조한다[I4][I5]. 국내 기업 맞춤형 RAG 챗봇 연구도 문서 학습, 서버 구성, 운영 관리의 필요성을 제시한다[D6].

2.3 간접 프롬프트 인젝션

간접 프롬프트 인젝션은 사용자가 직접 위험 명령을 입력하지 않아도 외부 문서나 웹 콘텐츠가 모델 행동을 바꾸는 위험이다[I7]. 본 연구는 실제 공격 절차를 재현하지 않고, synthetic 문서 안에 [REDACTED_INJECTION] 형태의 위험 신호만 넣어 방어 평가를 수행한다.

2.4 민감정보 노출 및 프라이버시 위험

업무용 생성형 AI 입력 문서에는 개인정보뿐 아니라 기술정보, 내부 정책, 계정 형태 문자열이 포함될 수 있다. 국내 연구는 중요 기술정보 개체명 인식과 비식별화가 업무용 생성형 AI 활용의 핵심 통제임을 제시한다[D5].

2.5 AI 시스템 재현성 및 평가 프로토콜

LLM 평가는 단일 정확도보다 평가 데이터, seed, 지표, 로그, 실패 사례를 함께 기록해야 한다[I1]. ML lifecycle 보증 연구는 데이터, 모델, 설정, 로그, 검증 증거를 추적 가능한 단위로 관리해야 한다고 설명한다[I8].

2.6 기존 연구의 한계

기존 연구는 LLM 보안 위협과 RAG 구조를 폭넓게 다루지만, 기업 문서가 색인되기 전 감사 항목, 위험 점수화, 정책 결정, 검색·생성 검증, 실행 로그를 하나의 제출 가능한 재현성 패키지로 묶는 절차는 상대적으로 부족하다.

Table 1. Related Research Mapping

구분	주요 문헌	본 연구 반영
국내 생성형 AI 보안·거버넌스	D1, D2, D3, D4	기업/국방/저작권/거버넌스 맥락의 감사 필요성
RAG 시스템	D6, I4, I5	검색 문서와 provenance 관리
간접 프롬프트 인젝션	I6, I7	retrieved context의 trust boundary
민감정보 보호	D5, I2, I3	중요 정보 탐지와 비식별화
재현성	I1, I8	데이터셋, seed, 로그, 지표 패키징

3. 위협 모델 및 연구문제

3.1 기업용 RAG 챗봇 구조

기업용 RAG 챗봇은 사용자 질문, 검색기, 벡터DB, 내부 문서, LLM 생성기, 출력 검증기, 감사 로그로 구성된다. Fig. 1은 공격면을 요약한다.

Figure: Fig. 1. RAG Attack Surface (figures/fig1_rag_attack_surface.md)

3.2 보호 자산

Table 2. Protected Assets and Threats

보호 자산	위협	감사 관점
내부 정책 문서	오래된 문서 검색, 출처 충돌	문서 생성일, 소유자, 승인 상태
시스템 프롬프트	간접 프롬프트 인젝션	위험 지시문 탐지
개인정보/기술정보	생성 응답 노출	민감정보 패턴 탐지와 비식별화
검색 로그	책임성 부재	seed, config, timestamp 저장
생성 응답	허위 출처, hallucination	근거 문서와 응답 검증

3.3 공격자 모델

공격자는 내부 문서 저장소, 협력사 문서, 외부 지식 클립, 오래된 정책 아카이브를 통해 오염 문서가 검색되도록 유도할 수 있다. 본 연구는 실제 시스템 침투나 실제 공격 payload 실행을 다루지 않는다.

3.4 공격면 분석

문서 수집 단계에서는 출처 미확인 문서가 들어올 수 있다. 전처리와 색인 단계에서는 chunk와 메타데이터가 분리되어 provenance가 손실될 수 있다. 검색 단계에서는 위험 문서가 상위 문서로 선택될 수 있다. 생성 단계에서는 LLM이 문서 속 지시문이나 민감정보를 답변에 반영할 수 있다.

3.5 연구질문

RQ1. 기업용 RAG 기반 생성형 AI 챗봇에서 문서 오염, 간접 프롬프트 인젝션, 민감정보 노출 위험은 어떤 공격면에서 발생하는가?

RQ2. 문서 수집, 색인, 검색, 생성 단계에서 위험 문서를 사전에 탐지하기 위한 보안 감사 항목은 어떻게 구성할 수 있는가?

RQ3. 제안 프레임워크는 단순 키워드 필터링 또는 정규표현식 기반 탐지 방식보다 위험 문서 탐지 성능을 향상시키는가?

RQ4. 제안 프레임워크는 정상 문서의 과도한 차단을 줄이면서 민감정보 노출과 프롬프트 인젝션 위험을 낮출 수 있는가?

RQ5. 재현 가능한 데이터셋, 설정 파일, 실행 로그, 평가 지표를 제공할 경우 산업 현장 보안 감사 절차로 활용 가능한가?

4. 제안 프레임워크

4.1 프레임워크 개요

RAG - DOCGUARD는 RAG 문서 오염 위험 탐지를 위한 재현성 중심 보안 감사 프레임워크다. 흐름은 다음과 같다.

문서 수집 -> 문서 전처리 -> 위험 신호 탐지 -> 위험 점수화 -> 색인 허용 / 차단 / 사람 검토
-> 검색 결과 검증 -> 생성 응답 검증 -> 감사 로그 저장 -> 재현성 패키징

Figure: Fig. 2. RAG - DOCGUARD Framework (figures/fig2_rag_docguard_framework.md)

4.2 감사 항목

Table 3. Audit Items of RAG - DOCGUARD

단계	감사 항목	출력
문서 수집	파일 출처, 문서 유형, 작성일, 소유자 확인	문서 메타데이터
전처리	chunk 크기, 중복 제거, 메타데이터 보존	전처리 로그
위험 탐지	악성 지시문, 개인정보, API 키, 출처 충돌 탐지	위험 라벨
위험 점수화	위험 유형별 점수 합산	risk_score
정책 결정	allow, block, review 분류	decision
검색 검증	검색 상위 문서 위험도 확인	retrieval_risk
생성 검증	응답 내 민감정보 · 정책 위반 확인	output_risk
사람 검토	애매한 문서 검토	human_decision
로그 저장	seed, config, timestamp, 결과 저장	run_log

4.3 위험 점수화와 정책 결정

본 구현은 다음 규칙을 사용한다. 프롬프트 인젝션 신호, 민감정보 placeholder, API key/token placeholder, 출처 미확인, 오래된 정책, 출처 충돌, 허위 출처 유도 신호를 가산하고, 검증된 공식 출처는 감산한다. 총점 0 - 29는 allow, 30 - 59는 review, 60 이상은 block으로 분류한다.

4.4 사람 검토 및 재현성 관리

review는 모델 성능 실패가 아니라 사람 검토가 필요한 운영 상태다. 따라서 본 연구는 review와 block을 위험 탐지 양성으로 묶어 Precision, Recall, F1 - score를 계산하고, 별도로 block 기준 Dangerous Document Prevention Rate를 계산한다.

5. 실험 설계

5.1 Synthetic RAG 문서 데이터셋

데이터셋은 04_final_paper/04_methodology_experiment/data/rag_security_dataset_100.csv에 저장했다. 모든 문서는 synthetic이며 실제 개인정보, 실제 계정, 실제 API 키, 실제 기업명은 포함하지 않는다.

Table 4. Dataset Distribution

문서 유형	개수	기대 결정
normal	20	allow

문서 유형	개수	기대 결정
indirect_prompt_injection	20	block
privacy_leakage	20	block
source_conflict	15	review
outdated_policy	15	review
hallucination_trigger	10	review
합계	100	-

5.2 비교 방법

Baseline 1은 no filter로 모든 문서를 allow 처리한다. Baseline 2는 keyword filter로 프롬프트 인젝션과 민감정보 위험 키워드를 탐지한다. Baseline 3은 regex filter로 synthetic 이메일, 전화번호, API key/token placeholder를 탐지한다. Proposed는 RAG - DOCGUARD 위험 점수화 규칙을 사용한다.

5.3 평가 지표

위험 문서 탐지에서 expected_decision이 review 또는 block이면 positive로 본다.

Precision = $TP / (TP + FP)$

Recall = $TP / (TP + FN)$

F1 - score = $2 * Precision * Recall / (Precision + Recall)$

False Positive Rate = $FP / (FP + TN)$

Dangerous Document Prevention Rate = 차단된 위험 문서 수 / 전체 위험 문서 수

Leakage Rate = allow 처리된 privacy_leakage 문서 수 / 전체 privacy_leakage 문서 수

Human Review Rate = review 처리 문서 수 / 전체 문서 수

5.4 실험 절차

Figure: Fig. 3. Experiment Pipeline (figures/fig3_experiment_pipeline.md)

실험은 Python 3.12.3에서 실행했다. 실행 파일은 04_final_paper/04_methodology_experiment/scripts/에 있으며 결과는 04_final_paper/04_methodology_experiment/outputs/에 저장했다.

6. 실험 결과

6.1 Baseline 비교 결과

Table 5. Metrics Summary

method	Precision	Recall	F1 - score	FPR	Dangerous Prevention	Leakage Rate	Human Review
baseline_no_filter	0.000000	0.000000	0.000000	0.000000	0.000000	1.000000	0.000000
baseline_keyword	1.000000	0.500000	0.666667	0.000000	0.500000	0.000000	0.000000
baseline_regex	1.000000	0.250000	0.400000	0.000000	0.250000	0.000000	0.000000
rag_docguard	1.000000	1.000000	1.000000	0.000000	0.500000	0.000000	0.400000

6.2 혼동행렬

Table 6. Confusion Matrix

method	TP	FP	TN	FN
baseline_no_filter	0	0	20	80
baseline_keyword	40	0	20	40
baseline_regex	20	0	20	60
rag_docguard	80	0	20	0

6.3 민감정보 노출 차단 결과

No filter는 privacy_leakage 문서를 모두 allow 처리해 Leakage Rate가 1.000000이었다. Keyword, regex, RAG - DOCGUARD는 synthetic placeholder 패턴을 탐지해 Leakage Rate 0.000000을 기록했다.

6.4 오탐 및 미탐 분석

Keyword filter는 프롬프트 인젝션과 민감정보 placeholder를 탐지했으나 source_conflict, outdated_policy, hallucination_trigger를 탐지하지 못했다. Regex filter는 형식 기반 민감정보 placeholder에는 강하지만 문서 출처 · 정책 충돌 · 오래된 정책에는 취약했다. RAG - DOCGUARD는 본 synthetic 조건에서 미탐과 오탐이 없었으나, 이는 실제 문서 분포가 아닌 규칙 기반 데이터셋의 결과다.

6.5 실패 사례 분석

실패 사례 전체는 04_final_paper/04_methodology_experiment/outputs/failure_cases.md에 기록했다. Baseline 실패는 대부분 위험 문서를 allow 처리한 false negative였다.

7. 논의

7.1 산업 현장 적용 가능성

RAG - DOCGUARD는 문서를 색인하기 전 위험 신호를 탐지하고, 애매한 문서를 사람 검토로 보내며, 실행 로그를 저장한다. 이는 기업용 RAG 챗봇 운영에서 감사 가능성과 책임성을 높이는 실무 절차로 활용 가능하다.

7.2 보안적 함의

기밀성 관점에서는 민감정보 placeholder와 중요 기술정보 탐지가 중요하다. 무결성 관점에서는 문서 출처 충돌과 오래된 정책 검토가 필요하다. 가용성 관점에서는 모든 위험을 block하지 않고 review를 둬으로써 정상 업무 차단을 줄일 수 있다. 책임성 관점에서는 실행 로그와 참고문헌 검증표가 필요하다.

또한 생성형 AI 서비스는 보안 위험뿐 아니라 저작권 침해와 같은 법 · 윤리 리스크를 동반한다. 강장목 공저 연구[D1]가 제시한 통합대응 메커니즘 관점은 RAG - DOCGUARD의 감사 로그, 출처 확인, 문서 소유자 확인, 최종 AI 활용 고지 절차를 보완하는 거버넌스 근거로 활용할 수 있다.

7.3 한계점

본 실험은 synthetic 데이터셋과 규칙 기반 탐지기만 사용했다. 실제 임베딩 모델, 벡터DB, LLM, 사용자 질의, 기업 문서 권한 구조를 평가하지 않았다. 또한 F1 - score 1.000000은 본 데이터셋에 대한 결과이며 실제 운영 성능을 의미하지 않는다.

7.4 향후 연구

향후 연구는 실제 공개 benchmark, 복수 임베딩 모델, 복수 LLM, 복수 seed, 독립 검토자 라벨링, 문서 provenance schema, 운영 로그 익명화 절차를 포함해야 한다.

8. 결론

본 연구는 기업용 생성형 AI 챗봇의 RAG 문서 오염 위험을 탐지하기 위한 RAG - DOCGUARD 프레임워크를 제안하고, 100개 synthetic 데이터셋과 3개 baseline 비교 실험을 통해 재현 가능한 평가 절차를 제시했다. 제안 방식은 본 synthetic 조건에서 위험 문서를 모두 block 또는 review로 분류했으며, 정상 문서의 오탐은 없었다. 최종 제출 전에는 공식 JKAIS HWP 양식 편집, 참고문헌 서지 재검증, PDF 변환 확인이 필요하다.

참고문헌

[D1] 전태석, 이용준, 안상수, 강장목, "생성형 인공지능의 저작권 침해 통합대응 메커니즘 연구," 융합보안 논문지, Vol.25 No.5, 2025.

- [D2] 최준석, 민병찬, "국방 폐쇄망 환경에서 제어 가능한 생성형 AI 보안 감사 에이전트 설계 및 구현," 융합보안 논문지, Vol.26 No.2, 2026.
- [D3] 최정완, "기업 내 생성형 AI 시스템의 보안 위협과 대응 방안," 융합보안 논문지, Vol.24 No.2, 2024.
- [D4] 이정찬, 윤철희, 이봉규, "생성형 AI 보안 취약점의 위험 전이와 위험기반 다층 거버넌스 설계: LLM · RAG · 딥페이크 분석 프레임워크를 중심으로," 정보통신정책연구, Vol.33 No.1, 2026.
- [D5] 이혜성, 한유나, "업무용 생성형 AI 모델의 안전한 활용을 위한 중요 기술정보 개체명 인식 및 비식별화 기법 개발 연구," 한국산업보안연구, Vol.16 No.특별호, 2026.
- [D6] 최광미, "검색증강생성(RAG) 기반 기업 맞춤형 챗봇(Chatbot) 시스템 구축 및 활용," 한국전자통신학회 논문지, Vol.19 No.6, 2024.
- [I1] Y. Chang et al., "A Survey on Evaluation of Large Language Models," ACM Transactions on Intelligent Systems and Technology, 2024. DOI: 10.1145/3641289.
- [I2] B. C. Das, M. H. Amini, and Y. Wu, "Security and Privacy Challenges of Large Language Models: A Survey," ACM Computing Surveys, 2025. DOI: 10.1145/3712001.
- [I3] Y. Yao et al., "A survey on large language model (LLM) security and privacy: The Good, The Bad, and The Ugly," High - Confidence Computing, 2024. DOI: 10.1016/j.hcc.2024.100211.
- [I4] B. Peng et al., "Graph Retrieval - Augmented Generation: A Survey," arXiv:2408.08921, 2024.
- [I5] Z. Zhu et al., "Graph - Based Approaches and Functionalities in Retrieval - Augmented Generation: A Comprehensive Survey," ACM Computing Surveys, 2026. DOI: 10.1145/3795880.
- [I6] X. Liu et al., "Prompting Frameworks for Large Language Models: A Survey," ACM Computing Surveys, 2026. DOI: 10.1145/3789253.
- [I7] K. Greshake et al., "Not what you've signed up for: Compromising Real - World LLM - Integrated Applications with Indirect Prompt Injection," arXiv:2302.12173, 2023.
- [I8] R. Ashmore, R. Calinescu, and C. Paterson, "Assuring the Machine Learning Lifecycle: Desiderata, Methods, and Challenges," ACM Computing Surveys, 2021. DOI: 10.1145/3453444.

AI 활용 고지

본 초안 작성에는 ChatGPT와 Codex가 사용되었다. 사용 목적은 저장소 구조 정리, 논문 목차 초안, synthetic 데이터셋 생성, 규칙 기반 실험 코드 작성, 참고문헌 검증표 초안 작성이다. 학회 양식, 참고문헌, 실험 결과는 공식 홈페이지, RISS/KCI, DOI/출판사 페이지, 실행 로그로 검증했으며 최종 제출 책임은 제출자에게 있다.